

External Penetration Test Report

Veltrix Onboard Platform — Web Application and External Infrastructure

Prepared for: Veltrix Onboard Pte. Ltd.

Prepared by: Greyline Security Ltd

Engagement reference	GL-2025-0412
Testing window	3 November 2025 to 21 November 2025
Report date	28 November 2025
Report version	1.1 — remediation status section (Section 5) updated 15 January 2026 with information supplied by Veltrix
Classification	Confidential — Veltrix Onboard Pte. Ltd. May be shared with Veltrix customers under NDA
Lead tester	S. Okafor, OSCP, CREST CRT
Quality review	H. Brandt, CREST CCT (App)

1. Executive summary

Greyline Security Ltd ("Greyline") was engaged by Veltrix Onboard Pte. Ltd. ("Veltrix") to perform a grey-box penetration test of the Veltrix Onboard web application and the externally exposed infrastructure supporting it. Testing took place between 3 and 21 November 2025 from Greyline's testing infrastructure, using two test tenants and user accounts at each application role provided by Veltrix.

Greyline identified **10 findings**: 1 Critical, 2 High, 3 Medium, 3 Low and 1 Informational. The overall risk rating for the assessed components is **High**, driven principally by a critical insecure direct object reference vulnerability that allowed an authenticated user of one tenant to download identity documents belonging to other tenants (VLX-2025-001). Given that the platform stores passport and identity document images on behalf of financial institutions, Greyline recommends that this issue is treated as an emergency fix and that Veltrix reviews access logs for evidence of prior exploitation.

Two High findings affect the authentication and case-management functions: the absence of rate limiting or account lockout on the local login endpoint (VLX-2025-002) and stored cross-site scripting in case notes (VLX-2025-003). The Medium and Low findings relate to session management, information disclosure, request forgery protection, legacy TLS configuration on the file-transfer gateway, and security headers.

Positive observations: the application enforces SAML single sign-on correctly for SSO-configured tenants; tenant isolation was correctly enforced on all tested endpoints other than the document download endpoint; the AWS perimeter exposed only the intended services; and no vulnerable third-party components with known public exploits were identified on the external perimeter.

Severity	Count	Finding references
Critical	1	VLX-2025-001
High	2	VLX-2025-002, VLX-2025-003
Medium	3	VLX-2025-004, VLX-2025-005, VLX-2025-006
Low	3	VLX-2025-007, VLX-2025-008, VLX-2025-009
Informational	1	VLX-2025-010

2. Scope and methodology

2.1 In scope

Component	Detail	Test type
Veltrix Onboard web application	https://app.veltrix.io — authenticated testing with two test tenants (TEN-GL-A, TEN-GL-B) and accounts at the Analyst, Approver and Tenant Administrator roles; unauthenticated testing of login, password reset and public pages	Grey-box
External infrastructure	Veltrix public IP ranges (2 x /28) including app.veltrix.io , www.veltrix.io , status.veltrix.io and legacy-sftp.veltrix.io	Black-box

2.2 Out of scope

The following components were out of scope for this engagement at Veltrix's request and were not tested:

- The Veltrix Onboard REST API (<https://api.veltrix.io>), including tenant API-key authentication and all API endpoints used for system-to-system integration by customers. Veltrix advised that the API is scheduled for a separate assessment.
- The Veltrix Onboard mobile applications (iOS and Android) and their back-end endpoints.
- The Veltrix support console and internal corporate systems.
- The Veltrix IQ document-processing feature (in beta at the time of testing).
- Denial-of-service testing, social engineering and physical security.

Findings relating to the document download endpoint (VLX-2025-001) were identified through the web application, which calls the same back-end service as the REST API. Greyline was unable to confirm whether the vulnerability is also exposed through the REST API because the API was out of scope.

2.3 Methodology

Testing followed the OWASP Web Security Testing Guide v4.2 and the Penetration Testing Execution Standard. Manual testing was supplemented with automated scanning. Severity ratings use CVSS v3.1 base scores, adjusted for context where indicated. Findings are reported with evidence, impact, and recommended remediation.

2.4 Limitations

Testing was time-boxed to 12 tester-days. A penetration test is a point-in-time assessment and cannot guarantee the absence of vulnerabilities. Greyline did not perform a retest as part of this engagement; Section 5 records remediation status as reported by Veltrix and has not been verified by Greyline.

3. Findings summary

Ref	Title	Severity	CVSS	Component
VLX-2025-001	Insecure direct object reference allows cross-tenant download of identity documents	Critical	9.1	Web application
VLX-2025-002	No rate limiting or account lockout on local login endpoint	High	8.1	Web application
VLX-2025-003	Stored cross-site scripting in case notes	High	7.4	Web application
VLX-2025-004	Session tokens remain valid after logout	Medium	6.5	Web application
VLX-2025-005	Verbose error messages disclose framework versions and stack traces	Medium	5.3	Web application
VLX-2025-006	Missing anti-CSRF protection on profile update endpoint	Medium	5.4	Web application
VLX-2025-007	TLS 1.0 and 1.1 and weak cipher suites enabled on legacy file-transfer gateway	Low	3.7	legacy-sftp.veltrix.io
VLX-2025-008	Missing security headers (Content-Security-Policy, HSTS preload)	Low	3.1	Web application
VLX-2025-009	Username enumeration via password reset response	Low	2.6	Web application
VLX-2025-010	Server header discloses web server software	Informational	0.0	External infrastructure

4. Detailed findings

VLX-2025-001 — Insecure direct object reference allows cross-tenant download of identity documents

Severity	Critical (CVSS v3.1 base score 9.1)
CVSS vector	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N
Affected component	GET /api/v2/documents/{documentId}/download (called by the web application)

Description

The document download endpoint identifies documents by a sequential integer identifier and does not verify that the requested document belongs to the tenant of the authenticated user. An authenticated Analyst in tenant TEN-GL-A was able to retrieve documents belonging to tenant TEN-GL-B, and — by iterating identifiers — documents belonging to production tenants, by modifying the documentId parameter. Other endpoints tested (case records, screening results, entity data) correctly enforced tenant scoping.

Evidence

Request GET /api/v2/documents/1048227/download with the TEN-GL-A session returned HTTP 200 and a PDF belonging to TEN-GL-B (filename confirmed with Veltrix). Requests for identifiers 1048000–1048300 returned 212 documents, of which 209 belonged to tenants other than TEN-GL-A, including passport image files. Greyline stopped enumeration immediately on confirming the issue, deleted retrieved files, and notified Veltrix on 6 November 2025 under the emergency notification protocol.

Impact

An authenticated user of any tenant — including a compromised or malicious user at any customer — can retrieve identity documents, proof-of-address and source-of-wealth documents belonging to every other tenant. This is a complete loss of confidentiality for the document vault across the platform.

Recommendation

Enforce tenant ownership checks in the document service for every document access; adopt non-sequential (UUID) identifiers; add automated authorisation tests covering cross-tenant access for all object types; review access logs since the endpoint's deployment for anomalous enumeration patterns and notify affected customers if exploitation is identified.

VLX-2025-002 — No rate limiting or account lockout on local login endpoint

Severity	High (CVSS v3.1 base score 8.1)
CVSS vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Affected component	POST /auth/login (local accounts, including tenant break-glass administrator accounts)

Description

The local login endpoint used by tenants without SSO and by break-glass administrator accounts does not implement rate limiting, progressive delays, CAPTCHA or account lockout. Greyline submitted 5,000 authentication attempts against a test account in 4 minutes without any throttling or alerting. The AWS WAF managed rule set in front of the application does not include a rate-based rule for this path.

Evidence

Automated submission of a credential list to POST /auth/login at approximately 20 requests per second returned distinguishable responses for valid and invalid credentials with no blocking. No alert was raised to the Veltrix security team during the test.

Impact

Credential stuffing and password spraying against local accounts, including customers' break-glass administrator accounts, is feasible at scale. Successful compromise of an administrator account grants full access to a tenant's data.

Recommendation

Implement rate limiting per account and per source IP, account lockout or progressive delays, and alerting on authentication anomalies; add a rate-based WAF rule for the login path; require MFA for all local accounts.

VLX-2025-003 — Stored cross-site scripting in case notes

Severity	High (CVSS v3.1 base score 7.4)
CVSS vector	AV:N/AC:L/PR:L/UI:R/S:C/H/I:H/A:N
Affected component	Case notes (POST /cases/{caseId}/notes) rendered in the case timeline view

Description

Case notes accept rich text that is sanitised on the client side only. A note containing an event-handler attribute in an image tag was stored unchanged and executed when the note was rendered for another user in the same tenant, including Approver-role users.

Evidence

A note containing `<img src=x onerror=...>` submitted by an Analyst executed JavaScript in the Approver's browser session and was able to read the session token from the page context and issue requests as the Approver.

Impact

An Analyst can execute actions as an Approver (for example, approving onboarding cases) and exfiltrate case data. Combined with the absence of session invalidation (VLX-2025-004), stolen tokens remain usable for an extended period.

Recommendation

Sanitise rich text server-side using an allow-list; encode output on render; set the session cookie as HttpOnly; deploy a Content-Security-Policy (see VLX-2025-008).

VLX-2025-004 — Session tokens remain valid after logout

Severity	Medium (CVSS v3.1 base score 6.5)
CVSS vector	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Affected component	Session management

Description

Logging out clears the session cookie in the browser but the server-side session is not invalidated. Captured session tokens remained valid for the full 24-hour absolute lifetime after logout.

Evidence

A session token captured before logout was replayed 6 hours after logout and returned authenticated content.

Impact

Session tokens stolen through XSS, malware or shared devices remain usable after the user believes they have logged out.

Recommendation

Invalidate sessions server-side on logout; reduce absolute session lifetime; implement idle timeout of 15 minutes for Approver and Administrator roles.

VLX-2025-005 — Verbose error messages disclose framework versions and stack traces

Severity	Medium (CVSS v3.1 base score 5.3)
CVSS vector	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected component	Web application error handling

Description

Malformed requests to several endpoints returned full stack traces including framework and library versions, internal hostnames and file paths.

Evidence

A malformed JSON body to POST /cases returned a stack trace referencing internal service hostnames and the application framework version.

Impact

Information disclosure that assists an attacker in targeting known vulnerabilities in the disclosed components.

Recommendation

Return generic error responses; log details server-side only; disable debug mode in production.

VLX-2025-006 — Missing anti-CSRF protection on profile update endpoint

Severity	Medium (CVSS v3.1 base score 5.4)
CVSS vector	AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Affected component	POST /account/profile

Description

The profile update endpoint accepts form-encoded requests without a CSRF token and the session cookie is not set with the SameSite attribute.

Evidence

A crafted page hosted by Greyline updated the notification email address of a logged-in test user without interaction beyond visiting the page.

Impact

An attacker can change a victim's notification email address, which is used in the password reset flow for local accounts.

Recommendation

Apply the application's existing CSRF token mechanism to all state-changing endpoints; set SameSite=Lax or Strict on session cookies.

VLX-2025-007 — TLS 1.0 and 1.1 and weak cipher suites enabled on legacy file-transfer gateway

Severity	Low (CVSS v3.1 base score 3.7)
CVSS vector	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected component	legacy-sftp.veltrix.io (HTTPS file-transfer portal on TCP/443, alongside SFTP on TCP/22)

Description

The file-transfer gateway used for batch exchange with customers exposes an HTTPS web portal that accepts TLS 1.0 and TLS 1.1 connections and offers CBC-mode cipher suites with 3DES. The main application (app.veltrix.io) correctly accepts TLS 1.2 and 1.3 only.

Evidence

TLS scan of legacy-sftp.veltrix.io:443 on 12 November 2025 reported TLS 1.0 and TLS 1.1 enabled and cipher suite TLS_RSA_WITH_3DES_EDE_CBC_SHA offered.

Impact

Clients negotiating legacy protocols are exposed to known downgrade and padding-oracle attacks; the configuration does not meet commonly mandated baselines (TLS 1.2 or higher only).

Recommendation

Disable TLS 1.0 and 1.1 and CBC/3DES cipher suites; align the gateway with the TLS policy applied to app.veltrix.io; consider decommissioning the HTTPS portal in favour of SFTP only.

VLX-2025-008 — Missing security headers

Severity	Low (CVSS v3.1 base score 3.1)
CVSS vector	AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Affected component	app.veltrix.io

Description

The application does not set a Content-Security-Policy header and the Strict-Transport-Security header lacks the preload directive.

Evidence

Response headers captured on 5 November 2025.

Impact

Reduced defence in depth against cross-site scripting and protocol downgrade.

Recommendation

Deploy a restrictive Content-Security-Policy; add the preload directive and submit the domain to the HSTS preload list.

VLX-2025-009 — Username enumeration via password reset response

Severity	Low (CVSS v3.1 base score 2.6)
CVSS vector	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected component	POST /auth/reset

Description

The password reset endpoint returns different responses for registered and unregistered email addresses.

Evidence

Registered addresses returned 'Reset email sent'; unregistered addresses returned 'Account not found'.

Impact

Supports targeted credential attacks (see VLX-2025-002).

Recommendation

Return a uniform response regardless of whether the address is registered.

VLX-2025-010 — Server header discloses web server software

Severity	Informational (CVSS v3.1 base score 0.0)
CVSS vector	n/a
Affected component	External infrastructure

Description

HTTP responses include a Server header identifying the web server software (nginx) without a version number.

Evidence

Response headers captured on 5 November 2025.

Impact

Negligible; no version information is disclosed. Reported for completeness.

Recommendation

Optionally suppress the Server header.

5. Remediation status (as reported by Veltrix, 15 January 2026)

The following status information was supplied by Veltrix on 15 January 2026 and is reproduced here at Veltrix's request. **Greyline has not performed a retest of any finding** and has not verified the status reported below. A retest engagement can be commissioned separately.

Ref	Severity	Status reported by Veltrix	Retest by Greyline	Veltrix notes
VLX-2025-001	Critical	Remediated (vendor attestation)	Not performed	Ownership check added to document service and deployed 19 December 2025 (43 days after notification). Identifier scheme unchanged. Log review for prior exploitation: 'no evidence identified' (internal review, scope and method not documented).
VLX-2025-002	High	Risk accepted	Not performed	Risk accepted by P. Raman, CTO, on 12 December 2025 on the basis that most customers use SSO. No compensating control recorded; no expiry date for the acceptance; customers not consulted.
VLX-2025-003	High	Remediated (vendor attestation)	Not performed	Server-side sanitisation library introduced, deployed 8 January 2026.
VLX-2025-004	Medium	In progress	Not performed	Session store changes scheduled for Q1 2026 release.
VLX-2025-005	Medium	Remediated (vendor attestation)	Not performed	Debug mode disabled in production, 2 December 2025.
VLX-2025-006	Medium	In progress	Not performed	Scheduled with VLX-2025-004.
VLX-2025-007	Low	Open	Not performed	Legacy HTTPS portal to be decommissioned in Q2 2026; TLS configuration unchanged pending decommissioning as some customers use the portal.
VLX-2025-008	Low	Open	Not performed	CSP rollout planned 2026.
VLX-2025-009	Low	Open	Not performed	Backlog.
VLX-2025-010	Informational	Not planned	n/a	Accepted as informational.

Appendix A — Testing team, tools and rating scale

Team

S. Okafor (lead), R. Venkataraman (tester), H. Brandt (quality review). Greyline Security Ltd is a CREST-accredited penetration testing provider.

Tools

Burp Suite Professional, Nmap, testssl.sh, Nuclei, ffuf, custom scripts.

Severity rating scale

Severity	CVSS v3.1 range	Recommended remediation timeframe
Critical	9.0–10.0	Immediately (emergency change)
High	7.0–8.9	Within 14 days
Medium	4.0–6.9	Within 30 days
Low	0.1–3.9	Within 90 days or next release
Informational	0.0	Discretionary

— End of report —